

Tight Auditing of Differentially Private Machine Learning

差分隐私机器学习的紧致隐私审计

数据安全期末汇报

论文研读与思考

2312331 王一诺

Milad Nasr et al., arXiv:2302.07956v1, 2023

1. 研究背景与动机
2. 论文贡献
3. 审计方法
4. 实验结果
5. 局限性与个人思考

普通 SGD 的隐私风险

- 模型可能记忆训练集中罕见或敏感样本
- 攻击者可进行成员推断、数据重构、记忆化分析
- 模型参数、输出概率、中间梯度都可能成为泄露通道

DP-SGD 的防护思路

1. 逐样本梯度裁剪
2. 聚合 batch 梯度
3. 加入高斯噪声
4. 用隐私会计计算 (ϵ, δ)

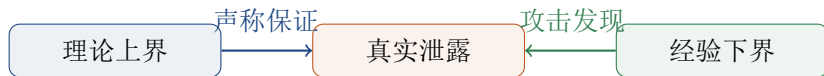
$$\Pr[M(D) \in S] \leq e^\epsilon \Pr[M(D') \in S] + \delta$$

理论保证依赖正确实现

- 裁剪顺序写错
- 噪声尺度配置错
- 随机数种子复用
- 采样与会计实现不一致

隐私审计的目标

- 通过攻击实验估计隐私泄露下界
- 若下界超过声称上界，说明实现或分析有问题
- 未发现泄露不等于证明安全



Q1: 理论分析是否只在最坏情况数据集上紧?

既有工作能在极端设置下审计到接近理论上界, 但这些设置常常是空数据集或完全对抗构造数据集。

Q2: 能否用很少训练次数完成紧致审计?

传统审计通常需要成千上万次训练; 对于大模型或真实系统, 这个成本几乎不可接受。

本文核心回答

在白盒威胁模型下, 使用 f -DP/GDP 审计可以在自然数据集上得到接近理论上界的隐私下界, 并把训练次数降到两次。

方法贡献

- 将隐私审计从 (ϵ, δ) -DP 扩展到 f -DP/GDP
- 利用高斯机制的 trade-off function
- 从常见观测推断尾部隐私事件

效率贡献

- 白盒设置中每个训练 step 都产生观测
- 审计成本从大量训练降为两次训练

实验贡献

- CIFAR-10、Purchase、随机数据集上接近理论上界
- 证明紧致性不只依赖最坏情况数据集

工程贡献

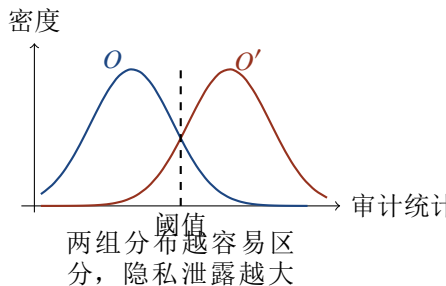
- 发现梯度裁剪、噪声采样、噪声尺度等实现 bug
- 适合作为 DP 训练库的测试工具

二元假设

$$H_0 : z \notin D, \quad H_1 : z \in D'$$

其中 z 是 canary 样本或 canary 梯度。

- FPR: 不含 canary, 却判断为含 canary
- FNR: 含 canary, 却判断为不含 canary



传统 epsilon-delta DP 审计的问题

它只使用通用 DP 区域，不利用机制本身的分布形状。由于 δ 通常很小，审计要估计极端尾部事件，因此需要大量观测。

GDP 的匹配性

对高斯机制，trade-off function 为：

$$T(\alpha) \geq \Phi(\Phi^{-1}(1 - \alpha) - \mu)$$

其中 μ 越大，区分越容易，隐私泄露越大。

核心洞察

既然 DP-SGD 的主要隐私机制是高斯噪声，就应利用高斯机制的完整错误率曲线，而不是只看粗粒度的 (ϵ, δ) 边界。

1. 构造 canary 梯度 g_0
2. 每一步采样两个 batch
3. 一组加入 canary, 一组不加入
4. 执行裁剪、聚合、加噪
5. 计算内积作为观测

审计统计量

$$o = \langle g_0, \tilde{g} \rangle, \quad o' = \langle g_0, \tilde{g}' \rangle$$

归一化后近似:

$$O \sim N(0, \sigma^2), \quad O' \sim N(1, \sigma^2)$$

为什么只需两次训练?

白盒审计观察每一步更新; 一次训练包含许多 step, 因此能从少量训练中积累大量观测。

威胁模型	攻击者能力	现实性	审计强度
白盒 + 梯度 canary	观察中间更新，插入指定梯度	较强	最强
白盒 + 输入 canary	观察中间更新，只能插入训练样本	中等	较强
黑盒访问	只能插入样本并观察最终模型	最现实	较弱

理解实验结果的关键

白盒结果回答“理论威胁模型下能否审计到上界”；黑盒结果更接近发布模型后的实际攻击能力。

数据集与模型

- CIFAR-10 + WRN-16
- CIFAR-10 + ConvNet
- Purchase + 三层全连接网络
- 随机像素和随机标签数据集

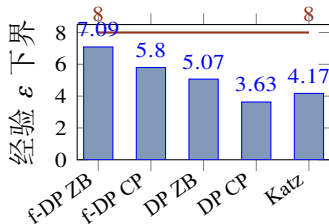
比较方法

- f -DP+ Clopper-Pearson
- f -DP+ Bayesian estimation
- (ϵ, δ) -DP+ Clopper-Pearson
- (ϵ, δ) -DP+ Bayesian estimation
- ϵ -DP+ Katz interval

默认设置

主要在白盒梯度 canary 威胁模型下审计，报告 95% 置信区间或可信区间。

结果一： f -DP 审计显著更紧



CIFAR-10 WRN-16, 理论 epsilon

- f -DPBayesian: 约 7.09
- f -DPCP: 约 5.80
- 传统 (ϵ, δ) -DPCP: 约 3.63

结论

使用机制匹配的 trade-off function, 是提升审计紧致性的主要原因。

结果二：自然数据集上也接近理论上界

理论 ϵ	CIFAR WRN	CIFAR Conv	Purchase	Random
1	0.95	0.94	0.89	0.90
4	3.73	3.80	3.60	3.52
8	7.09	7.12	6.94	7.12
16	13.95	13.80	13.80	15.14

表中为 f -DPBayesian 审计得到的经验 ϵ 下界，摘自论文 Table 1。

对 Q1 的回答

DP-SGD 的隐私分析并非只在完全对抗数据集上紧；在 CIFAR-10、Purchase、随机数据集上，强白盒审计也能得到接近理论预算的下界。

三类 bug

- 先平均梯度再裁剪
- 噪声采样偏差或种子复用
- 噪声尺度小于目标值

代表性发现

- 声称上界： $\epsilon = 1.27$
- 真实上界到 $\epsilon = 1.57$ 时， f -DP 审计已能发现违反
- 传统审计在真实上界到 $\epsilon = 2.17$ 时仍可能发现不了

工程意义

隐私审计可以作为 DP 训练库的测试工具，帮助发现普通准确率测试无法暴露的隐私 bug。

结果四：黑盒审计仍有明显差距

黑盒设置

- 训练 1000 个包含 canary 的模型
- 训练 1000 个不包含 canary 的模型
- 仅观察最终模型在 canary 上的输出

主要结果

- CIFAR-10 + WRN, 理论 $\epsilon = 8$ 时, 下界约 1.6
- 其他模型或数据集下界更低
- 随机数据集上几乎得不到非平凡下界

解释

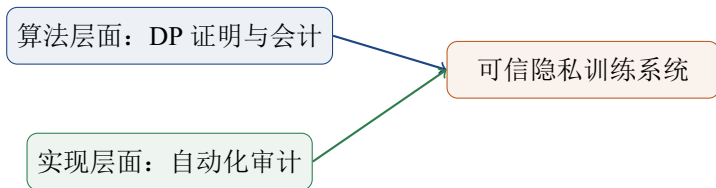
黑盒攻击能力弱、最终模型输出信息有限, 且子采样机制使审计更难紧致。

优点

- 问题贴近真实隐私系统
- 理论工具与工程审计结合
- 显著降低白盒审计成本
- 能检测具体实现错误

局限

- 最强结果依赖白盒梯度 **canary**
- 审计只给下界，不能替代理论证明
- 子采样机制下仍不够紧
- 大模型和生成模型仍需验证



我的理解

差分隐私不应只停留在“报告一个 ϵ ”。真实系统需要同时检查理论假设和代码实现，就像密码协议既需要安全证明，也需要实现审计与测试。

面向黑盒真实部署

- 更强的输入 canary 与查询策略
- 面向 API 输出的统计量设计
- 第三方监管和模型发布后评估

面向大模型微调

- 文本 canary: 罕见短语、特殊格式、虚构身份
- LoRA / Adapter 微调的泄露模式
- 文本生成输出下的黑盒审计指标

面向联邦学习

- 客户端级 DP 审计
- 非独立同分布数据与动态参与率
- 安全聚合与可审计性的平衡

面向工程测试

- 将审计集成到 Opacus、TF Privacy 等框架
- 作为 DP-SGD primitive 的 CI 单元测试

1. 本文提出基于 f -DP/GDP 的紧致隐私审计方法，比传统 (ϵ, δ) -DP 审计更贴合 DP-SGD 的高斯噪声机制。
2. 在白盒 canary 设置下，本文能在自然数据集上得到接近理论隐私预算的经验下界，并将审计训练次数降低到两次。
3. 本文展示了审计发现 DP-SGD 实现 bug 的能力，说明隐私保护系统需要“形式化证明 + 经验审计”双轨机制。

一句话概括

这篇论文的价值不是提出新的隐私防御，而是让我们更可靠地检查隐私防御是否真的生效。

Q&A

THANKS